



worldskills ASEAN Manila2025

54 Cyber Security

Test Project



Contents

Contents..... **2**

Introduction to Test Project **3**

Introduction **5**

Physical Topology..... 5

Logical Topology 6

Table 1. VM Finished Configuration Summary 7

Description of project and tasks **9**

ISP..... 9

Firewall configuration..... 9

Table 1. Firewall settings..... 10

PKI..... 12

WINSRV1 12

LINSRV1 14

LAN clients..... 14

WinClient3 15

Instructions to the Competitor **15**

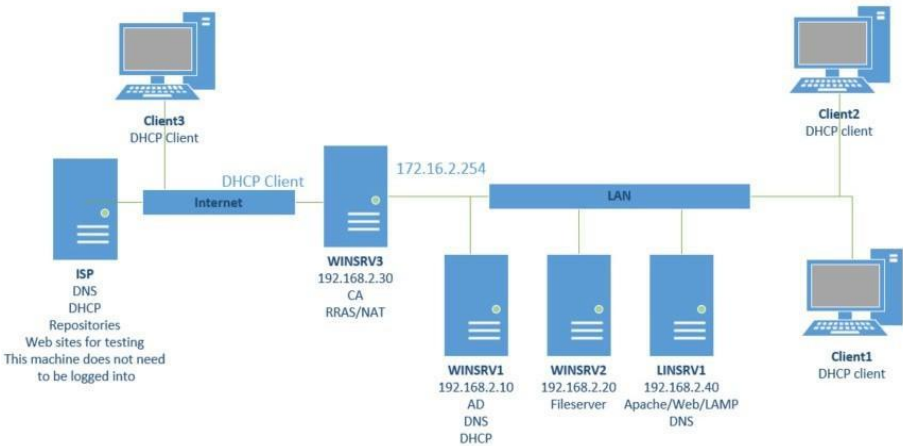
Table 2. GPO Policy Recommendations..... 15

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

Introduction to Test Project

Our friends over at skill 39 have built a network for a client, and everything works as expected, but things are not as secure as they need to be. The network when first examined was as follows:

Pre-project topology:



Following a security assessment, a number of changes needed to be made in order to make the network more secure: installation and configuration of a proper firewall, hardening of the domain and the Linux machines, management of a Public Key Infrastructure, and segmenting the network into different subnets, amongst other things, all need to be accomplished.

You will be given a list of tasks to implement to work towards hardening the network and the systems on it, you and your partner will have to best decide how to spend your time to get all the configurations done. You will be assessed on the completeness of these tasks based on both a configuration and functional standpoint, so remember to test your configurations as you go.

Use the following login credentials to log onto the ESXi server for the afternoon portion of the activity:

IP Address: **192.168.1.1**

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)



14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025
Adopted & Adapted from WorldSkills Lyon 2024

User: **pmuser**

Password: **Maria@57X3**

Login credentials for the competitor Laptops are as follows: User: **competitor0**

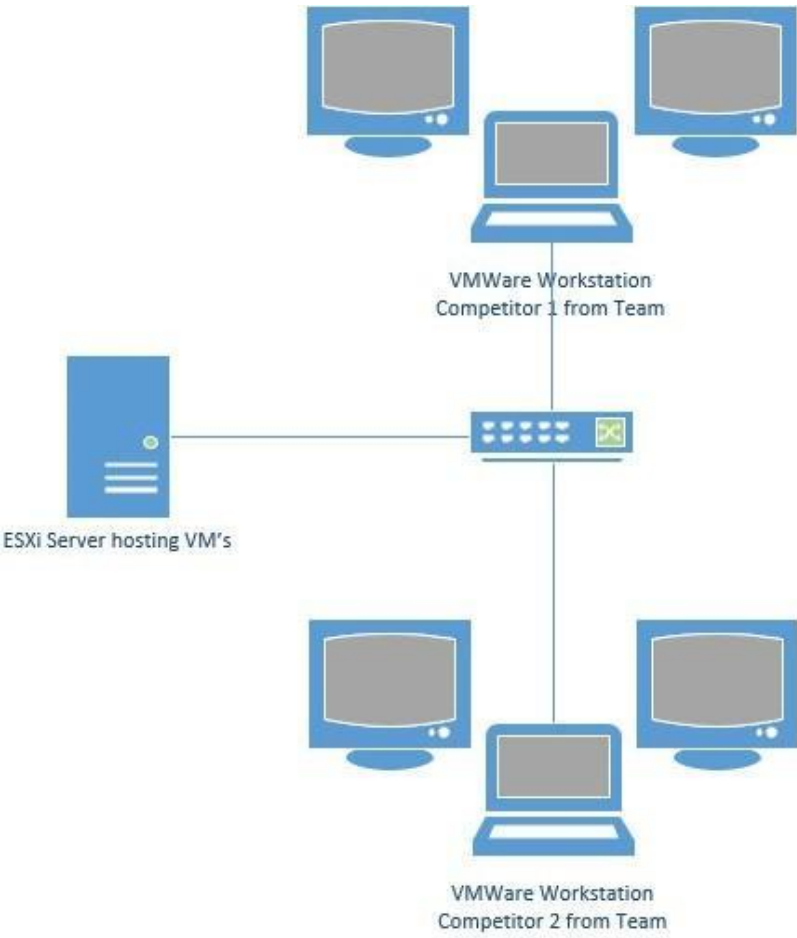
Password: **Boracay@14!**

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

Introduction

Physical Topology

The physical topology of this project is as follows: competitors from each team will use VMWare Workstation to access VM's hosted on a local ESXi server. All teams will have the same configuration and VM's, but only have access to their own VM's. As per the following diagram:



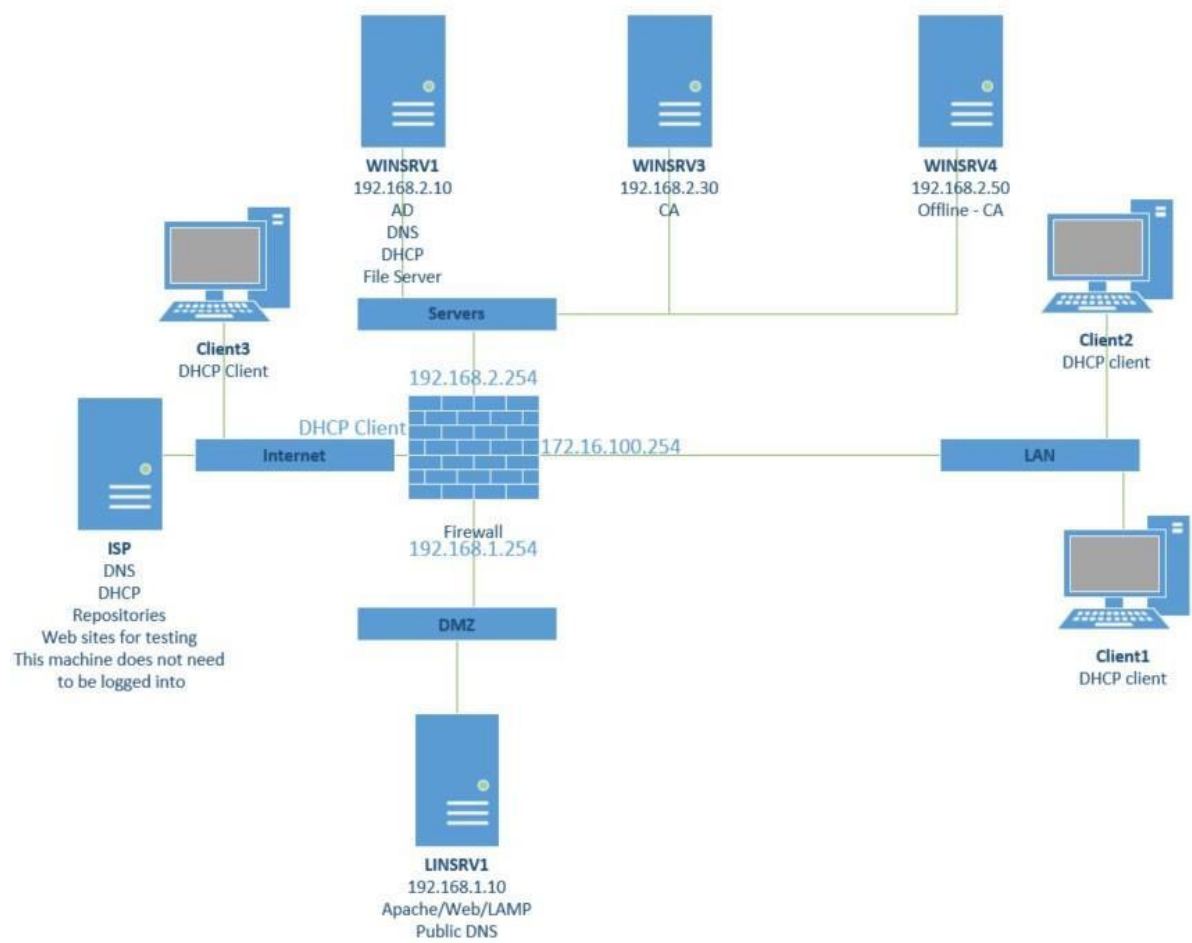
Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025
Adopted & Adapted from WorldSkills Lyon 2024

Logical Topology

The logical topology of the VM’s provided on the ESXi server is as follows with the following Network configuration:



Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025
Adopted & Adapted from WorldSkills Lyon 2024

The VM’s should all be preset with the correct IP addresses, subnet masks, and gateways, but it is the Competitor’s responsibility to verify or identify any errors or discrepancy between the VM’s provided and this documentation, and to correct them if necessary.

Table 1. VM Finished Configuration Summary

VIRTUAL MACHINE	VLAN	IP ADDRESS	NOTES	CREDENTIALS
ISP	Internet		Offers DNS and website access to locally connected machines – serves as the “fake Internet” for connection testing. Competitors should not need access to this machine for any reason.	N/A
Client1 and Client2	LAN	DHCP Client	Internal access and testing	Two machines have been provided to allow testing of different settings in the event competitors need to be testing different things at the same time. Access via any existing Domain Users with a password of P@ssw0rd
Client3	Internet	DHCP Client	For testing VPN and Websites in DMZ	Login in using a local administrator with a password of P@ssw0rd

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025

Adopted & Adapted from WorldSkills Lyon 2024

VIRTUAL MACHINE	VLAN	IP ADDRESS	NOTES	CREDENTIALS
WINSRV1	SERVERS	192.168.2.10/24	DC for AD, DNS and DHCP for Internal Clients (CLIENT1 & 2) and Servers (WINSRV3 & 4)	All Users in AD have a password of "P@ssw0rd" – do not modify the passwords unless required by the project
WINSRV3	SERVERS	192.168.2.30/24	Issuing CA	CA servers have been installed.
WINSRV4	SERVERS	192.168.2.50/24	Offline Root CA	
LINSRV1	DMZ	192.168.1.10/24	Public website hosting	root/P@ssw0rd competitor/P@ssw0rd Access to setup as per the project. All required software is pre-installed but may need to be configured.
Firewall	Connected to all vLANS	192.168.2.254 (Server) DHCP Client (Internet) 192.168.1.254 (DMZ) 172.16.100.254 (LAN)	All traffic except that specified in the project is blocked.	admin/pfsense

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

Description of project and tasks

Configure and test the settings for the following systems:

ISP

This machine simulates the Internet. It is running a DHCP server which will service the WAN interface on the firewall and Client3, the external client. This machine will operate as the “upstream” DNS server and hosts two websites to test the Firewall configuration from Internal clients. The two websites are:

<https://www.nationalmuseum.gov.ph>

<https://www.starcity.com.ph>

The purpose of these websites is for testing firewall configurations and has been created intentionally with a self-signed certificate.

Competitors will not need to logon to this machine, and do not have logon credentials for it. It needs simply to be on to provide DHCP/DNS/web services for testing.

Firewall configuration

The firewall is installed in its base configuration, with IP and interfaces connected to the proper subnets and IPs assigned. No other configurations have been done. Default logon to PFSense is admin/pfsense.

It is important to functionally test firewall configurations from the machines on various networks to verify functionality and not rely strictly on configurations.

- Set admin user password to be “**P@ssw0rd**”
- Setup DHCP for LAN clients on PFSense – WinSRV1 should be the DNS Server

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025
Adopted & Adapted from WorldSkills Lyon 2024

Block all traffic except as listed:

Table 2. Firewall settings

SOURCE NETWORK	DESTINATION NETWORK	PORTS/SERVICES ALLOWED	
LAN	Internet	Outbound and return traffic to WAN allowed	Client 1/Client 2 is allowed to access internet (WAN)
LAN	DMZ	SSH, HTTP, HTTPS, DNS allowed to LINSRV1	Client1 /Client 2 can perform password-based authentication via SSH protocol to LINSRV1, and access website which configured from the LINSRV1.
LAN	Servers	For AD TCP/UDP - 53, 88, 135, 137-139, 389, 443 445, 464, 636, 3268-3269 For PKI: TCP – 9389	For Active Directory Domain Services (ADDS) and CA certificate requests.
WAN	DMZ	Inbound WAN traffic to the website at DMZ allowed (HTTP, HTTPS)	Website should be accessible from internet to DMZ interfaces. Add OpenVPN(1194) when it is needed for VPN setup and test cases.
Servers	As necessary for services	As necessary for services	
DMZ	Servers/AD	TCP/UDP - 53, 88, 135, 137-139, 389, 445, 464, 636, 3268-3269	For LINSRV1 to join the domain at AD.

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025

Adopted & Adapted from WorldSkills Lyon 2024

After configuring inbound-outbound ports (allowed/not) in every interface, it is necessary to implement the following on the firewall as well.

- OpenVPN
 - Set up a VPN connection using OpenVPN where a VPN client queries AD and uses a certificate produced by WinSRV3 as the CA cert. Packages have been pre-downloaded.
 - Member from VPN Users group would be able to connect from CLIENT3 to OpenVPN – can use a self-signed certificate if you cannot get a CA signed certificate.
 - OpenVPN shall be protected by credentials. This can be configured from pfSense directly. You can create the specific user for OpenVPN with username **VPNUser** and password **P@ssw0rd**. Members of the VPN Users group will need to be authenticated first in order to use the VPN.
 - Verify if the OpenVPN is already up/working, user (outside of the internal network) can try to check the connectivity to any interface.
 - The VPN user would be able to access the website hosted at the Servers VLAN.
- Snort
 - Install SNORT as IDS – should log all traffic going out to the Internet. Package has been pre-downloaded
 - Attempts to access **www.starcity.com.ph** should be logged at Snort.
 - Modify this custom rule at snort as appropriate and apply it to the WAN interface:

drop tcp any any <> a.b.c.d/24 any (flags: FPU; msg: "Possible XMAS scan"; sid: 100001)
 - This rule can be tested by initiating a port scan in nmap from CLIENT3.
- Internet Access
 - Set rules that will allow your Internal clients as well as CLIENT 3 (using VPN) to access the **www.nationalmuseum.gov.ph** site on the Internet, but will block access to **www.starcity.com.ph**.

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025

Adopted & Adapted from WorldSkills Lyon 2024

PKI

2 Tier PKI

WinSRV4 will be offline RootCA. This is already configured and powered off. You should not need to turn this on unless you wish to troubleshoot an issue. It is included for completeness and in industry it would be completely powered off and removed from network access.

WinSRV3 will be the issuing CA.

This machine is already configured as the subordinate (issuing) CA for the domain. Complete the following tasks:

- Create a new Group Policy Object called "**certenroll**" so that computers on the domain will automatically receive a certificate from the issuing CA through application of the GPO. These GPO's should be set to **autoenroll**.
- When an internal client browses to either of the following websites, it should not be prompted with a certificate error on connection, since the root-ca should be recognized as a trusted CA via policy.
 - Through autoenrollment, WinSRV3 should receive a certificate for the Web server in the IIS installation. (Website: <https://webtest.manila.com>)
 - Also install a certificate onto the LINSRV1 for the Website there. (Website: <https://www.manila.com>)

WINSRV1

Note – Wireshark has been installed on this machine for troubleshooting purposes.

- Create a password policy that requires all domain users' passwords to be 8 characters in length, and must be changed **every 60 days**.
- Create a fine-grained password policy that requires members of the executive group to have a **16-character** long password. **Change password to P@ssw0rdP@ssw0rd during testing for one member of executive group.**
- Create a login banner/title that says "WorldSkills **ASEAN Manila**"
- Create a login banner/text that says "**Authorized access only**"
- **Create a GPO called "lockout" that will lock accounts after 3 failed logon attempts for all domain users. Account duration lockout is 60 seconds.**
- Create a GPO called "restrict control panel" that will restrict access to the control panel – which is only applicable to **all users, except for the executive group**.
- Create a GPO called "disabled add and remove program panel" that does not allow executive group to use control panel to add new program, uninstall or change a program.
- Create a GPO called **"autolock" that will auto lock screen after 10 seconds of inactivity** – only applicable

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025
Adopted & Adapted from WorldSkills Lyon 2024

- to the **executive group**.
- Create a share on WinSRV1 following best practices at the local path C:\shares\pictures shared as "pictures" that will allow the **Read access (R) to the Marketing group, Full Control (FC) for Executive group**, no access for anyone else.
 - In the C:\shares\pictures folder, you will find a picture called "**park.jpg**", set auditing on this file so it is logged when read by a member of any group.

LINSRV1

- Join LinSRV1 to manila.com domain.
- Ensure all domain-joined machines can resolve LinSRV1 by name to its IP address using DNS.
- **User Access Control**
 - Only allow domain users C1 and C2 to access the system via SSH.
 - If domain integration fails, create local users C1 and C2 matching the expected credentials.
 - Grant administrative privileges only to C1 and C2 using the sudo mechanism.
 - No other users should have sudo access or administrative privileges.
- **Local Firewall Configuration**
 - Ensure the firewall is active and enabled to start at boot.
 - Permanently allow only required services through the firewall.
- **Secure SSH Configuration**
 - Configure SSH to listen on port 2022.
 - Disable root login via SSH.
 - Restrict SSH access to only the C1 and C2 users.
 - Limit maximum authentication attempts to 3.
- **Password Policy Enforcement for users**
 - Minimum length of 10 characters
 - Include lowercase, uppercase, numeric, and special characters.
 - Password expires every 30 days.
 - Trigger expiry warnings starting on day 25.
- **HTTPS Web Server Hardening**
 - Make the hosted website (/var/www/manila) accessible via HTTPS.
 - Prefer a certificate signed by the WinSRV3 CA; otherwise, use a self-signed certificate.

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)

14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025

Adopted & Adapted from WorldSkills Lyon 2024

- Configure HTTP to redirect to HTTPS.
- Limit the website's exposure to domain users only. A domain user should be able to access the website from the Internet through his/her domain login credential.
- SELinux Enforcement
 - Ensure SELinux is enabled and set to Enforcing mode.
 - Adjust SELinux contents and policies as necessary so that the httpd service can access /var/www/manila and function properly.

LAN clients

Note – Wireshark and PuTTY have been installed on these machines for troubleshooting purposes.

- Use these machines to functionally verify requirements specified in other sections
- Refer to this table for the list of AD users for testing purpose:

Table 3. AD users

ID	Job Title	Department	City	OU	Groups
M001	Brand Marketing Specialist	Marketing	Manila	Manila	Marketing
M002	Customer Experience Representative	Customer Service	Manila	Manila	Customer Service
M003	Store Sales	Sales	Manila	Manila	Sales
M004	Operations Manager	Operations and Logistics	Manila	Manila	Executive
S001	Marketing Manager	Marketing	Singapore	Singapore	Executive
C1	Technical Support	IT	Manila	Manila	IT
C2	Technical Support	IT	Singapore	Singapore	IT

WinClient3

Note - Nmap is installed if you wish to initiate a port scan on the firewall.

- Remote access to network via VPN
- Test website access for DMZ

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)



14th WorldSkills ASEAN Competition • Manila, Philippines

Version 1.0 • Updated on 25 February 2025
Adopted & Adapted from WorldSkills Lyon 2024

Instructions to the Competitor

All existing user accounts have a password of **P@ssw0rd** including the root and administrator accounts. We know that this is a weak password to use and have done this for ease of use and assessment at the competition and should not be considered a vulnerability. Please do not change or reset the passwords unless directed by the project as experts will be unable to login and assess your configurations.

All server VM’s have statically configured IP addresses. You are responsible verifying if these are set correctly in the case that a setting on a virtual machine is different from this document.

All configurations must survive a system reboot.

Country 1 (CE)	Country 2 (DCE)	Country 3 (E)	Country 4 (E)	Country 5 (E)
Country 6 (E)	Country 7 (E)	Country 8 (E)	Country 9 (E)	Country 10 (E)